

CYBER SECURITY COMPLETE NOTES

Easy Language • Real-Life Examples • Important Topics Highlighted

★ *Red star = Important Topic (read carefully, exam / interview favorite)*

MMOC TEACH
MADE BY PRAVENDRA

INDEX

- ★ **1. Introduction to Cyber Security**
- ★ **2. CIA Triad - Confidentiality, Integrity, Availability**
 - 3. Types of Hackers
- ★ **4. Malware - Virus, Worm, Trojan, Ransomware**
- ★ **5. Phishing Attacks**
 - 6. Social Engineering
- ★ **7. Denial of Service (DoS) and DDoS Attacks**
 - 8. Man-in-the-Middle (MITM) Attack
- ★ **9. SQL Injection**
 - 10. Cross-Site Scripting (XSS)
 - 11. Password Attacks (Brute Force & Dictionary Attack)
 - 12. Cryptography Basics
- ★ **13. Encryption vs Hashing**
 - 14. Symmetric vs Asymmetric Encryption
 - 15. Firewalls
- ★ **16. VPN (Virtual Private Network)**
 - 17. IDS and IPS (Intrusion Detection / Prevention Systems)
- ★ **18. Authentication - Multi-Factor Authentication (MFA/2FA)**
- ★ **19. Ethical Hacking and Penetration Testing**
- ★ **20. OWASP Top 10**
 - 21. Cyber Laws - IT Act 2000 (India)
 - 22. Incident Response and Cyber Forensics

★ 1. Introduction to Cyber Security [IMPORTANT TOPIC]

Explanation:

Cyber Security means protecting computers, mobile phones, networks, and data from theft, damage, or unauthorized access. As more of our life moves online — banking, shopping, chatting — protecting this digital world becomes very important.

The main goal of cyber security is to keep information safe, private, and available only to the right people.

Key Points:

- Protects data, devices, and networks from attackers.
- Covers personal use (your phone, email) and business use (company servers, websites).
- A single weak password or an unpatched app can open the door for an attacker.

Example:

A hospital keeps patient records on its computers.

Cyber security tools stop hackers from stealing or changing this sensitive medical data.

Real-Life Example:

In 2017, the WannaCry ransomware attack locked computers in hospitals and companies across 150+ countries, demanding money to unlock the files.

💡 *Note: Cyber security is not just the IT team's job — every person using a computer or phone plays a part in staying safe.*

★ 2. CIA Triad - Confidentiality, Integrity, Availability [IMPORTANT TOPIC]

Explanation:

The CIA Triad is the foundation of cyber security. It has three goals that every security system tries to protect.

Key Points:

- Confidentiality -> only authorized people can see the data (example: your bank password stays private).
- Integrity -> data stays accurate and is not changed by unauthorized people (example: nobody secretly edits your bank balance).
- Availability -> data and services are accessible whenever needed (example: your banking app works and doesn't crash).

Example:

A student's exam result should be: seen only by that student and staff (Confidentiality), not tampered with (Integrity), and available when the student wants to check it (Availability).

Real-Life Example:

A DDoS attack that crashes a website is an attack on Availability — the site becomes impossible to access, even though no data was stolen.

3. Types of Hackers

Explanation:

Not all hackers are criminals. Hackers are usually grouped by their intention.

Key Points:

- White Hat -> ethical hackers who test systems LEGALLY to find and fix weaknesses.
- Black Hat -> criminal hackers who break into systems to steal or harm.
- Grey Hat -> hack without permission, but usually without bad intentions (a mix of both).

Example:

A company hires a White Hat hacker to try breaking into its own website, so they can fix any weak points before a real criminal finds them.

Real-Life Example:

Many big tech companies like Google and Facebook run 'Bug Bounty' programs, paying White Hat hackers money for finding and reporting security flaws.

★ 4. Malware - Virus, Worm, Trojan, Ransomware [IMPORTANT TOPIC]

Explanation:

Malware (short for 'malicious software') is any harmful program designed to damage, steal, or take control of a computer without the owner's permission.

Key Points:

- Virus -> attaches itself to a file and spreads when that file is opened or shared.
- Worm -> spreads on its own across a network, without needing a person to open anything.
- Trojan -> hides inside something that looks harmless or useful, like a fake app.
- Ransomware -> locks or encrypts your files and demands money to unlock them.

Example:

You download a 'free movie player' app, but it secretly installs a Trojan that steals your saved passwords.

Real-Life Example:

The WannaCry ransomware (2017) encrypted files on infected computers and demanded payment in Bitcoin to restore access.

★ 5. Phishing Attacks [IMPORTANT TOPIC]

Explanation:

Phishing is when an attacker sends a fake message (usually an email or text) that looks like it's from a trusted source, to trick you into giving away personal information like passwords or bank details.

Key Points:

- Often creates urgency: 'Your account will be blocked in 24 hours!'
- Contains a fake link that looks almost identical to a real website.
- Spear Phishing -> a phishing attack aimed at one specific person, using personal details to seem more convincing.

Example:

You get an email that looks like it's from your bank, asking you to 'verify your account' by clicking a link and entering your password. The link actually leads to a fake website built to steal that password.

Real-Life Example:

Many people have lost money after clicking fake 'KYC update' or 'prize winner' links sent through SMS or WhatsApp.

 *Note: Always check the sender's actual email address and the website URL carefully before entering any personal information.*

6. Social Engineering

Explanation:

Social engineering means tricking a PERSON (instead of hacking a computer directly) into giving away confidential information or access, usually by pretending to be someone trustworthy.

Example:

A stranger calls an office employee pretending to be from 'IT Support' and asks for their login password to 'fix an urgent issue'.

Real-Life Example:

Famous hacker Kevin Mitnick was well known for using social engineering — talking his way past security — more than actual computer hacking skills.

 *Note: No real IT department or bank will EVER ask you for your full password over a phone call or message.*

★ 7. Denial of Service (DoS) and DDoS Attacks [IMPORTANT TOPIC]

Explanation:

A Denial of Service (DoS) attack floods a website or server with so much fake traffic that it becomes too slow or crashes completely, making it unavailable to real users. A DDoS (Distributed Denial of Service) attack does the same thing, but using MANY computers at once, making it much more powerful.

Example:

Imagine 10,000 fake visitors trying to open a shopping website at the exact same second — the server gets overloaded and real customers cannot access the site anymore.

Real-Life Example:

In 2016, a huge DDoS attack on a company called Dyn took down major websites like Twitter, Netflix, and Reddit for several hours.

8. Man-in-the-Middle (MITM) Attack

Explanation:

In a Man-in-the-Middle attack, an attacker secretly places themselves BETWEEN two people who are communicating (like you and a website), and can read or even change the information being sent, without either side knowing.

Example:

You connect to a free public Wi-Fi at a cafe. An attacker on the same network secretly intercepts the data you send, including passwords typed on non-secure websites.

Real-Life Example:

This is why banking apps warn you: 'Avoid using public Wi-Fi for financial transactions.'

 *Note: Websites starting with https:// (the 's' means secure) are much harder for an attacker to intercept than plain http:// sites.*

★ 9. SQL Injection [IMPORTANT TOPIC]

Explanation:

SQL Injection is an attack where a hacker types specially crafted text into a website's input box (like a login form), tricking the website's database into running unwanted commands — sometimes revealing or deleting all its data.

Example:

A poorly protected login form might allow an attacker to type something like ' OR '1'='1 into the password field, tricking the system into logging them in without knowing the real password.

Real-Life Example:

SQL Injection has been used in several real data breaches to steal entire databases of usernames and passwords from poorly secured websites.

 *Note: Developers prevent this by properly checking and 'sanitizing' every piece of user input before using it in a database command.*

10. Cross-Site Scripting (XSS)

Explanation:

Cross-Site Scripting happens when an attacker manages to insert malicious code (usually JavaScript) into a website, which then runs inside the browser of anyone who visits that page — often to steal cookies or session information.

Example:

An attacker posts a comment on a website containing a hidden script. When other users view that comment, the hidden script secretly runs in their browser and steals their login session.

Real-Life Example:

Many older, poorly-secured comment sections and forums have been exploited using XSS to hijack user accounts.

11. Password Attacks (Brute Force & Dictionary Attack)

Explanation:

A Brute Force attack tries EVERY possible combination of characters until it guesses the correct password. A Dictionary attack is faster — it only tries commonly used passwords and words from a pre-made list.

Example:

An attacker's program automatically tries thousands of passwords per second (like '123456', 'password', 'qwerty') against a login page until one works.

Real-Life Example:

This is exactly why websites now often lock an account or add a delay after several wrong password attempts — to slow down brute force attacks.

 *Note: A long password using a mix of letters, numbers, and symbols is much harder to brute-force than a short, simple one.*

12. Cryptography Basics

Explanation:

Cryptography is the science of protecting information by converting it into a secret, unreadable format, so that only the intended person can understand it. It is the foundation of almost all data security online.

Key Points:

- Plaintext -> the original, readable message.
- Ciphertext -> the scrambled, unreadable version of the message.
- A 'key' is used to lock (encrypt) and unlock (decrypt) the message.

Example:

The message 'HELLO' could be scrambled into something like 'KHOOR' using a simple secret shifting technique, and only someone with the right key can turn it back into 'HELLO'.

Real-Life Example:

Every time you see a padlock icon in your browser's address bar, cryptography is protecting the data flowing between you and that website.

★ 13. Encryption vs Hashing [IMPORTANT TOPIC]

Explanation:

Encryption and hashing both scramble data, but they work very differently. Encryption is TWO-WAY — data can be unlocked back to its original form using a key. Hashing is ONE-WAY — once data is hashed, it normally cannot be turned back into its original form.

Key Points:

- Encryption -> used when data needs to be read again later (example: a private message).
- Hashing -> used when we only need to CHECK a value, not read it back (example: storing passwords).

Example:

Websites don't store your actual password. Instead, they store its 'hash'. When you log in, your typed password is hashed again and compared to the stored hash.

Real-Life Example:

This is why even the website's own staff usually cannot see your real password — they can only see its unreadable hash.

14. Symmetric vs Asymmetric Encryption

Explanation:

Symmetric encryption uses the SAME key to both lock (encrypt) and unlock (decrypt) data — it's fast, but the key must be shared safely with the other person. Asymmetric encryption uses TWO different keys: a public key (shared with everyone) to lock the data, and a private key (kept secret) to unlock it.

Example:

Symmetric: You and a friend agree on a secret password to lock and unlock a zip file. Asymmetric: You give everyone a public 'mailbox slot' to drop letters in, but only you have the private key to open the mailbox and read them.

Real-Life Example:

HTTPS websites use asymmetric encryption first to safely exchange a key, then switch to faster symmetric encryption for the rest of the session.

15. Firewalls

Explanation:

A firewall acts like a security guard between your computer/network and the internet. It watches incoming and outgoing traffic and blocks anything that looks suspicious or is not allowed, based on a set of rules.

Example:

A company firewall might be set up to block all traffic from a particular country known for frequent attacks, while allowing normal traffic from trusted regions.

Real-Life Example:

Both Windows and Mac computers come with a built-in firewall that is usually turned on by default to filter unwanted network connections.

★ 16. VPN (Virtual Private Network) *[IMPORTANT TOPIC]*

Explanation:

A VPN creates a secure, encrypted 'tunnel' between your device and the internet. This hides your real location and activity from your internet provider and from attackers, especially useful on public or untrusted networks.

Example:

You connect to public airport Wi-Fi and turn on a VPN. Even if an attacker on the same Wi-Fi tries to intercept your traffic, all they see is scrambled, unreadable data.

Real-Life Example:

Many companies require employees to use a VPN to safely access internal company systems while working from home.

17. IDS and IPS (Intrusion Detection / Prevention Systems)

Explanation:

An IDS (Intrusion Detection System) constantly watches network traffic and ALERTS the security team if it notices suspicious activity, but does not stop it. An IPS (Intrusion Prevention System) goes a step further — it automatically BLOCKS the suspicious activity in real time.

Example:

An IDS notices unusual login attempts at 3 AM from an unknown country and sends an alert. An IPS would automatically block that login attempt immediately.

Real-Life Example:

Large companies often use both together — IPS to stop known attack patterns instantly, and IDS to catch anything unusual for a human to review.

★ 18. Authentication - Multi-Factor Authentication (MFA/2FA)

[IMPORTANT TOPIC]

Explanation:

Authentication means proving who you are before being allowed access. Multi-Factor Authentication (MFA) adds extra layers of proof beyond just a password, making it much harder for an attacker to break in, even if they steal your password.

Key Points:

- Something you KNOW -> a password or PIN.
- Something you HAVE -> your phone (an OTP code, an authenticator app).
- Something you ARE -> your fingerprint or face (biometrics).

Example:

When you log into your bank app, you enter your password (something you know) AND an OTP sent to your phone (something you have) — this combination is called 2FA (Two-Factor Authentication).

Real-Life Example:

Most email providers like Gmail strongly recommend turning on 2-Step Verification to protect accounts even if the password is leaked.

★ 19. Ethical Hacking and Penetration Testing [IMPORTANT TOPIC]

Explanation:

Ethical hacking is when a skilled security professional is given LEGAL PERMISSION to try breaking into a system, in order to find weaknesses before a real criminal hacker does. This process of actively testing systems is called Penetration Testing (or 'pen testing').

Key Points:

- Reconnaissance -> gathering information about the target.
- Scanning -> looking for open doors (weaknesses) in the system.
- Gaining Access -> actually trying to break in, using found weaknesses.
- Reporting -> writing a detailed report of what was found, so it can be fixed.

Example:

A company hires an ethical hacker to attempt to break into its online store. The hacker finds a weak spot in the checkout page and reports it, so the company can fix it before a real attacker finds it.

Real-Life Example:

Certifications like CEH (Certified Ethical Hacker) and OSCP are well known qualifications for people working in this exact field.

★ 20. OWASP Top 10 [IMPORTANT TOPIC]

Explanation:

OWASP (Open Web Application Security Project) is a well-known organization that publishes a regularly updated list called the 'OWASP Top 10' — the ten most common and dangerous security weaknesses found in websites and web applications.

Key Points:

- Includes issues like Injection attacks (e.g. SQL Injection), Broken Authentication, and Cross-Site Scripting (XSS).
- Used worldwide by developers as a checklist to build safer websites.

Example:

A web development team checks their new website against the OWASP Top 10 list before launching it, to catch common mistakes early.

Real-Life Example:

Many companies now require new developers to study the OWASP Top 10 as a standard part of secure coding training.

21. Cyber Laws - IT Act 2000 (India)

Explanation:

The Information Technology Act, 2000 (IT Act) is India's main law dealing with cyber crimes and electronic commerce. It defines what counts as a cyber crime in India and the punishments for offenses like hacking, data theft, and online fraud.

Key Points:

- Covers offenses like hacking, identity theft, and spreading viruses.
- Gives legal recognition to electronic records and digital signatures.
- Amended in 2008 to include more modern cyber crimes.

Example:

If someone hacks into another person's email account in India without permission, they can be legally punished under the IT Act, 2000.

Real-Life Example:

Cyber crime cells in Indian police departments use the IT Act as the legal basis for investigating and prosecuting online crimes.

22. Incident Response and Cyber Forensics

Explanation:

Incident Response is the planned process an organization follows immediately after a cyber attack is discovered, to contain the damage, remove the threat, and recover safely. Cyber Forensics is the process of investigating AFTER an attack — collecting digital evidence to understand exactly what happened and who was responsible.

Key Points:

- Identify -> notice that an attack has happened.
- Contain -> stop it from spreading further.
- Eradicate -> remove the attacker's access completely.
- Recover -> restore normal, safe operations.

Example:

After discovering a data breach, a company's security team immediately disconnects the affected server from the network, then begins investigating log files to find how the attacker got in.

Real-Life Example:

Digital forensic experts are often called in after major breaches to trace attackers and provide evidence usable in legal cases.